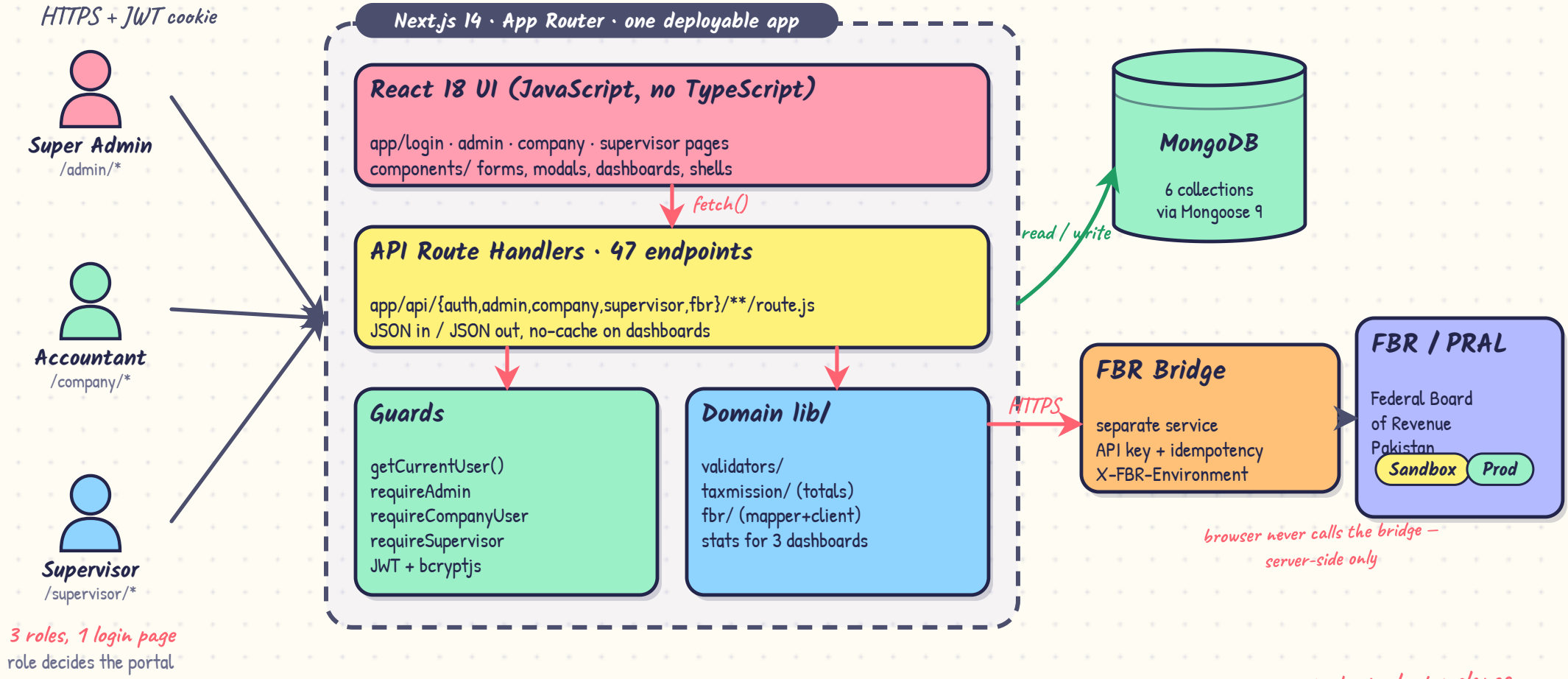
The Big Picture

who talks to what



← tech stack at a glance

Frontend

- React 18
- Next 14 App Router
- Plain CSS + CSS modules
- Fonts: Tilt Neon, TikTok Sans

Backend

- Next route handlers
- Mongoose 9 models
- JWT (7 days) + cookies
- bcryptjs hashing

Integration

- FBR Bridge HTTP client
- 35 s default timeout
- Receipts audit log
- Sandbox / Production

Reporting

- Asia/Karachi months
- Admin / Accountant / Supervisor
- CSV export (supervisor)
- Print-ready A4 modals

Quality

- yarn lint
- test:admin · test:company
- test:supervisor
- Mock-API browser checks

Layers + Folder Map

top to bottom

request

1 Pages & Components

app//page.js · components/***

React client components, reducers, CSS modules

2 Layout Shells

AdminSidebar · AdminTopbar · PortalShell

Role shells: nav, search, account menu, mobile drawer

3 API Route Handlers

*app/api/**/route.js*

Parse request → guard → validate → model → JSON

4 Auth Guards

*lib/auth/**

getCurrentUser · requireAdmin · requireCompanyUser · requireSupervisor

5 Domain Logic

lib/validators · lib/taxmission · lib/fbr

Rules, totals, scenario profiles, FBR mapping, stats

6 Data Models

models/.js · lib/mongodb.js*

Company · User · Submission · FbrReceipt · InvoiceItem · ReferenceData

response ↑

lib/fbr

- bridgeClient.js HTTP client
- mapSubmissionToInvoice.js
- scenarioProfiles.js SN018/SN019
- fbrStatus.js · exampleInvoice.js

lib/validators + taxmission

- submissionValidator (shared client + server)
- companyValidator · userValidator
- calculateInvoiceTotals
- prepareFbrPayload

lib/{admin,company,supervisor}

- dashboardStats.js builders
- reportingPeriods (Karachi tz)
- readAccess · syncCompanyPersonnel

styles/ + public/images

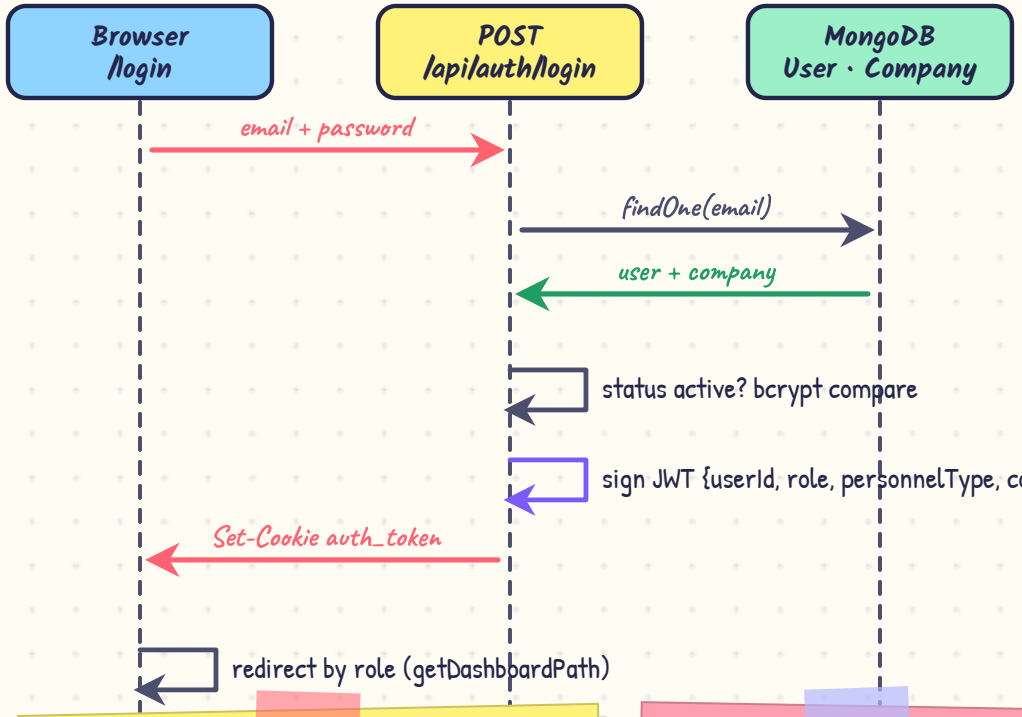
- variables.css · print.css
- sidebar / hero / login art
- CSS modules per portal

rule: pages never touch the database directly

Login, JWT + Role Guards

who may do what

Login sequence



Cookie flags

- httpOnly · sameSite=lax · path=/
- secure in production · 7 day maxAge

Safe failures

- Wrong user/password → 401
- Inactive user/company → 403
- No password set → 401

Two roles, three personas

- super_admin → /admin/dashboard
- company_user + accountant → /company/dashboard
- company_user + supervisor → /supervisor/dashboard

Passwords

- bcryptjs hash
- ≥ 8 chars for supervisors
- verify-password gate for deletes

On every API request

1. cookies().get("auth_token")
2. verifyToken(JWT)
3. User.findById → must be active
4. company_user ⇒ Company must be active
5. requireX() → role check or 403

Live checks

- Role changes take effect immediately
- Deleted / inactive users lose access
- No trust in stale JWT claims

Access matrix

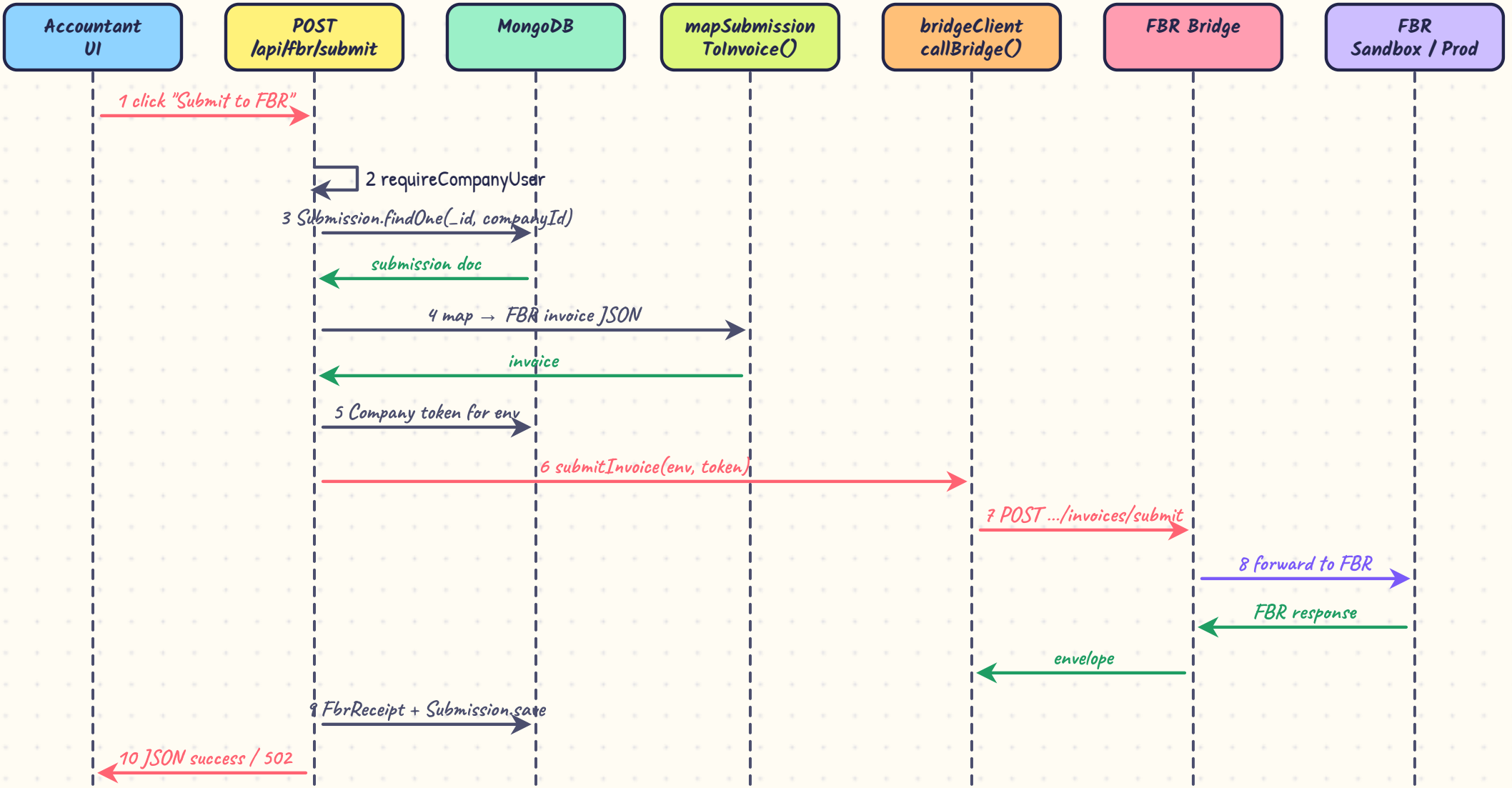
Area	Admin	Accountant	Supervisor
/admin/* + API	✔	✘	✘
/company/* + API	✘	✔	✘
/api/fbr/submit	✘	✔	✘
/supervisor/* (GET only)	✘	✘	✔
/api/auth/*	✔	✔	✔

Every query is tenant-scoped

- Company routes always filter by companyId from the session
- Supervisor APIs: GET only, no-store cache, safe company fields, no FBR tokens

Submit an Invoice to FBR

end-to-end sequence



Headers sent to the bridge

- Authorization · X-Request-ID
- X-Idempotency-Key = <id>:submit
- X-FBR-Environment · X-FBR-Token (opt.)

Token selection

- production → fbrProductionToken
- sandbox → fbrSandboxToken
- empty → header omitted

Always logged

- FbrReceipt created for
- success AND failure

Result

- ok → status submitted
- else → status failed
- submittedAt stamped

API + Page Route Map

47 endpoints

ARCHITECTURE 5/5

Admin /api/admin

requireAdmin

- GET /stats · /search?q=
- GET POST /companies
- GET PUT DEL /companies/[id]
- GET POST /users
- GET PUT DEL /users/[id]
- GET /submissions · /submissions/[id]
- GET POST /reference-data
- PUT DEL /reference-data/[id]

Accountant /api/company

requireCompanyUser

- GET /profile · /stats
- GET POST /invoice-items
- PUT DEL /invoice-items/[id]
- GET POST /submissions
- GET PUT DEL /submissions/[id]
- POST /submissions/[id]/validate
- POST /submissions/[id]/prepare-payload
- POST /submissions/[id]/submit (placeholder)

Supervisor /api/supervisor

requireSupervisor

- GET /stats · /profile
- GET /submissions · /fbr-invoices
- GET read-only, company-scoped, no-store

the real FBR push lives here ↓

FBR /api/fbr

requireCompanyUser

- POST /submit → bridge + receipt
- GET DEL /receipts · /receipts/[id]

Auth /api/auth

public / session

- POST /login · /logout
- GET /me
- POST /change-password · /verify-password

Shared

session

- GET /api/reference-data (dropdown lists)
- POST /api/seed (setup, secret key)

UI page routes

Admin

/admin/dashboard
/admin/companies · /new · /[id]
/admin/users · /new · /[id]
/admin/submissions · /[id]
/admin/reference-data

Accountant

/company/dashboard
/company/submissions/new · /[id]
/company/records (submissions)
/company/fbr-records · invoice-items
/company/profile

Supervisor

/supervisor/dashboard
/supervisor/submissions
/supervisor/fbr-invoices
/supervisor/profile

Conventions

- Dynamic segments use [id] folders · routes export GET / POST / PUT / DELETE functions
- Guards return { error } 403 early · dashboards add Cache-Control: no-store · pages redirect by role

tip: green GET = read-only